

Alexander Ticket

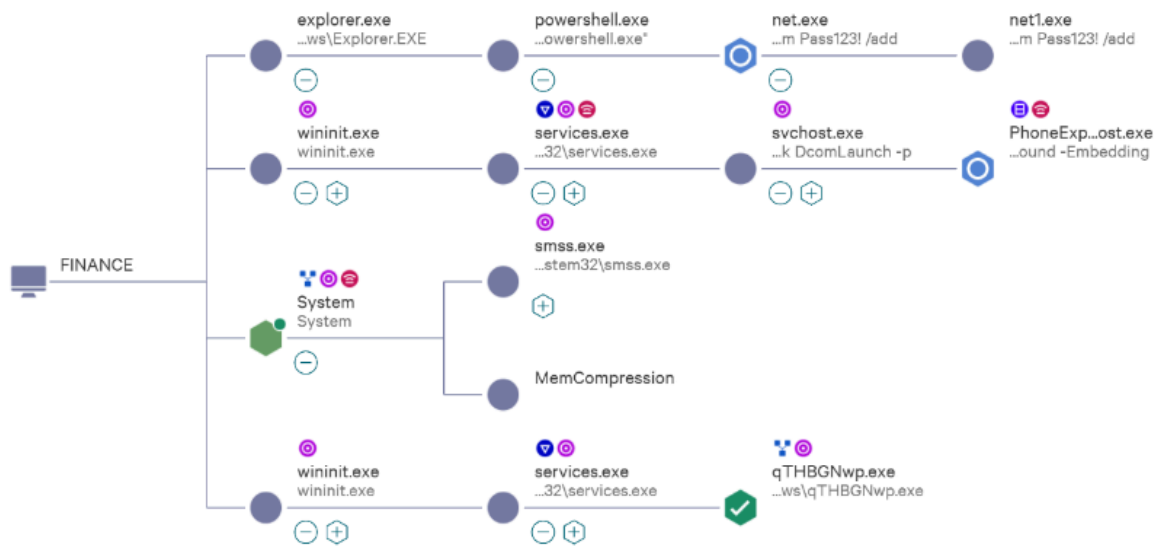
Note: This report has been sanitized for public sharing.

All internal IPs, hostnames, and CrowdStrike URLs have been redacted or replaced with simulated values.

Report was originally prepared for Jira; internal console links are not publicly accessible. Query references shown for context

The Summary :

The alert indicates a sequence of suspicious activities including lateral movement via SMB admin shares, defense evasion through UMPPC hook bypassing, and the unauthorized creation of a new user account for persistence on host [redacted].



Confidence - Medium

Description

38/100

This automated lead detected the following behaviors:

- A user created a new user account. Attackers can create new accounts to maintain their foothold on a system. Investigate the active user and newly created account.
- A process appears to have performed a system call by bypassing UMPPC hooks.
- A file written to the file-system was classified as Adware/PUP based on its SHA256 hash.
- This file is classified as Adware/PUP based on its SHA256 hash.
- Service Control Manager executed a file written by SMB. Adversaries can use lateral movement to execute malicious files from remote systems. Review the file and process tree

Techniques: Create Account, Impair Defenses, PUP, SMB/Windows Admin Shares

Involved hosts: FINANCE

Detections and context 5 items

Severity	Detect time	Process on host	Type	Command line	Tactic via technique
---	2025/02/18 20:05:54	qTHBGNwp.exe on FINA...	Automated lead conte...	C:\Windows\qTHBGNwp...	Lateral Movement via S...
---	2025/02/18 20:05:52	PhoneExperienceHoste...	Automated lead conte...	"C:\Program Files\Windo...	Defense Evasion via Imp...
---	2025/02/18 20:05:52	net.exe on FINANCE by ...	Automated lead conte...	"C:\Windows\system32\...	Persistence via Create A...
Low	2025/02/18 20:05:51	qTHBGNwp.exe on FINA...	Endpoint detection	C:\Windows\qTHBGNwp...	Malware via PUP
Low	2025/02/18 20:05:51	System on FINANCE by ...	Endpoint detection	System	Malware via PUP

CrowdStrike Link:

- **Incident(CrowdScore):**

(internal link, redacted for confidentiality)

- **1. Endpoint Detection (Malware/PUP) :**

(internal link, redacted for confidentiality)

- **2. Endpoint Detection Persistence - Create Account :**

(internal link, redacted for confidentiality)

Description

A multi-stage intrusion was detected on host [redacted-host], characterized by lateral movement via administrative shares and unauthorized efforts to establish persistence. The incident began with the deployment of a malicious executable, **qTHBGNwp.exe**, which was written to the **C:\Windows** directory via **SMB/Windows Admin Shares** and executed by the Service Control Manager. This binary was classified as **Malware/PUP**, indicating a remote delivery of a potentially malicious payload.

Simultaneously, the compromised [redacted] account was leveraged to ensure long-term access. Command-line analysis confirms the use of **net.exe** to create a new local user account (**adam**) with a static password (**Pass123!**). This manual account creation is a standard **Persistence** technique used to maintain a foothold after the initial session is terminated.

To facilitate these actions and evade detection, the adversary performed **Defense Evasion** by utilizing **PhoneExperienceHost.exe** to bypass User Mode Process Prevention (UMPPC) hooks. This sophisticated maneuver aimed to impair the Falcon sensor's visibility into the malicious process tree. The combination of lateral movement from a remote system, proactive account creation, and low-level hook bypassing indicates a targeted manual intrusion designed to compromise sensitive financial data and maintain a persistent presence within the network.

◆ Host Information:

Hostname: **[redacted-host]**

Operating System: Windows 10

External IP: [redacted]

Local IP Address: [redacted internal IP]

Host Type: Workstation

◆ User Information:

1. Initial Compromised Account:

Username: **[redacted]**

Local Admin: Yes

Login Type: REMOTE_INTERACTIVE (RDP Session)

Login Time: Feb. 2, 2025 09:57:05

Login Domain: **[redacted-domain]**

2. Targeted System Account:

Username: **FINANCE\$**

Local Admin: Yes

Login Time: Feb. 19, 2025 12:54:16

Login Domain: [redacted-domain]

◆ Tactic & Technique:

Technique: [Malware](#) via [PUP](#), [Persistence](#) via [Create Account](#), [Defense Evasion](#) via [Impair Defenses](#), [Lateral Movement](#) via [SMB/Windows Admin Shares](#).

MITRE ATT&CK ID: **T1021.002 , T1136.001 , T1562.001 , T1059**

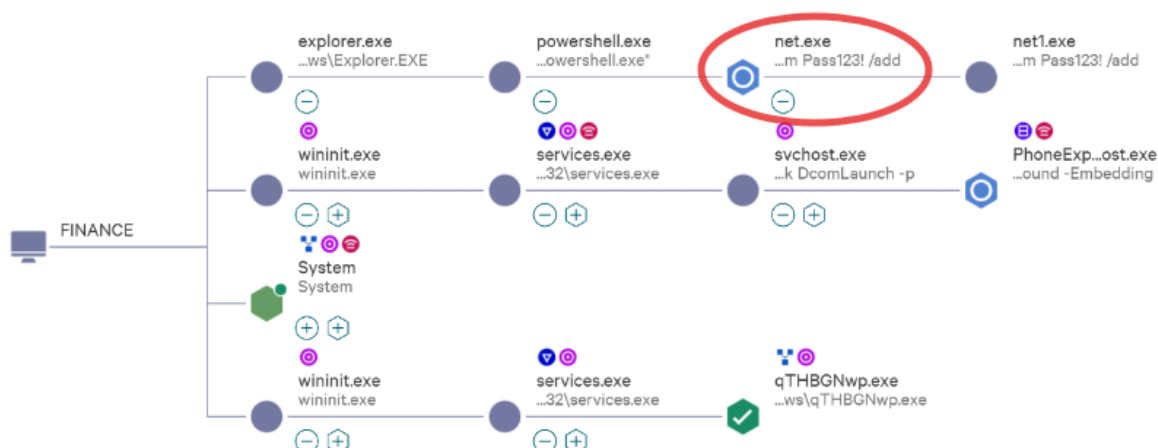
Investigation Findings and Analysis:

Note: In the CrowdStrike Falcon console, several interactive processes (e.g., **explorer.exe**, **powershell.exe**, **csrss.exe**) appear grouped under the **System** root node.

This grouping occurs because the EDR platform correlates kernel-level events—such as **Injected Threads** between **dwm.exe** and **csrss.exe** and the use of network drivers—into a single **Incident Context (Lead)**.

Chronology: Forensic timestamps confirm that the interactive user session activity (19:39 – 19:51) occurred **before** the automated SMB file transfer (20:04). We have separated these into distinct phases for analytical accuracy.

Observed Command 1:



① Phase 1 : Persistence (Unauthorized Account Creation)

Process: explorer.exe

Start time: Feb. 18, 2025 19:23:41

End time: Feb. 18, 2025 19:29:24

Command line

C:\Windows\Explorer.EXE

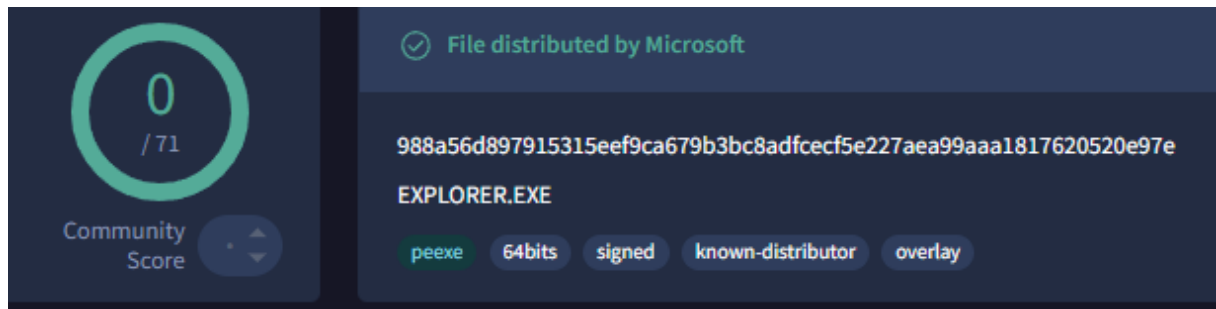
File path

\Device\HarddiskVolume2\Windows\explorer.exe

Executable SHA256

988a56d897915315eef9ca679b3bc8adfcecf5e227aea99aaa1817620520e97e

[Result there] <https://www.virustotal.com/gui/file/988a56d897915315eef9ca679b3bc8adfcecf5e227aea99aaa1817620520e97e/relations>



The lineage begins with the primary user shell. This confirms the activity originated from an interactive RDP session. Although the binary is legitimate (0/71 on VT), the 4/7 malicious execution parents suggest this session context is frequently targeted for **hijacking**. The adversary utilized the existing [redacted] session to bypass the need for a new authentication event.

Process: powershell.exe

Start time: Feb. 18, 2025 19:26:37

End time: Feb. 18, 2025 19:29:21

Command line

"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"

File path

\Device\HarddiskVolume2\Windows\System32\WindowsPowerShell\v1.0\powershell.exe

Executable SHA256

9785001b0dcf755eddb8af294a373c0b87b2498660f724e76c4d53f9c217c7a3

[Result there] <https://www.virustotal.com/gui/file/9785001b0dcf755eddb8af294a373c0b87b2498660f724e76c4d53f9c217c7a3/detection>

0

/ 71

Community Score

-24

File distributed by Microsoft

9785001b0dcf755eddb8af294a373c0b87b2498660f724e76c4d53f9c217c7a3

PowerShell.EXE

peexe

detect-debug-environment

long-sleeps

known-distributor

legit

64bits

Matches rule **System File Execution Location Anomaly** by Florian Roth (Nextron Systems), Patrick Bareiss, Anton Kutepov, oscd.community, Nasreddine Bencherchali at Sigma Integrated Rule Set (GitHub)

↳ Detects a Windows program executable started from a suspicious folder

Matches rule **PowerShell Core DLL Loaded By Non PowerShell Process** by Tom Kern, oscd.community, Natalia Shornikova, Tim Shelton, Roberto Rodriguez (Cyb3rWard0g), OTR (Open Threat Research) at Sigma Integrated Rule Set

↳ Detects loading of essential DLLs used by PowerShell, but not by the process powershell.exe. Detects behaviour similar to meterpreter's "load powershell" extension.

Matches rule **PSScriptPolicyTest Creation By Uncommon Process** by Nasreddine Bencherchali (Nextron Systems) at Sigma Integrated Rule Set (GitHub)

↳ Detects the creation of the "PSScriptPolicyTest" PowerShell script by an uncommon process. This file is usually generated by Microsoft Powershell to test against Applocker.

Matches rule **Renamed Powershell Under Powershell Channel** by Harish Segar, frack113 at Sigma Integrated Rule Set (GitHub)

↳ Detects renamed powershell

Flagged by the **Sigma Rule: System File Execution Location Anomaly**. The use of PowerShell as a child of Explorer is a common bridge for adversaries to transition from a GUI environment to a command-line interface for rapid execution of administrative tools. Community indicators mark this specific execution context as highly suspicious.

Process: net.exe

Start time: Feb. 18, 2025 19:27:20

End time: Feb. 18, 2025 19:27:20

Executable SHA256

9f376759bcbcd705f726460fc4a7e2b07f310f52baa73caaaaa124fddbdf993e

[Resultthere]<https://www.virustotal.com/gui/file/9f376759bcbcd705f726460fc4a7e2b07f310f52baa73caaaaa124fddbdf993e/detection>]

0

/ 71

Community Score

File distributed by Microsoft

9f376759bcbcd705f726460fc4a7e2b07f310f52baa73caaaaa124fddbdf993e

net.exe

peexe

known-distributor

assembly

idle

detect-debug-environment

legit

64bits

Despite the clean signature, 9 malicious execution parents and community reports link this behavior to discovery and credential access patterns.

Identified by CrowdStrike as an automated lead:

Detection: Persistence via Create Account

Detection Timestamp: Feb. 18, 2025 20:05:52

Command line

```
"C:\Windows\system32\net.exe" user adam Pass123! /add
```

File path

```
\Device\HarddiskVolume2\Windows\System32\net.exe
```

Analysis shows unusual entropy consistent with Software Packing. Legitimate system binaries should not be packed; this indicates potential binary tampering or "Process Hollowing" to mask malicious intent.

Process: net1.exe

Start time: Feb. 18, 2025 19:27:20

End time: Feb. 18, 2025 19:27:20

Command line

```
C:\Windows\system32\net1 user adam Pass123! /add
```

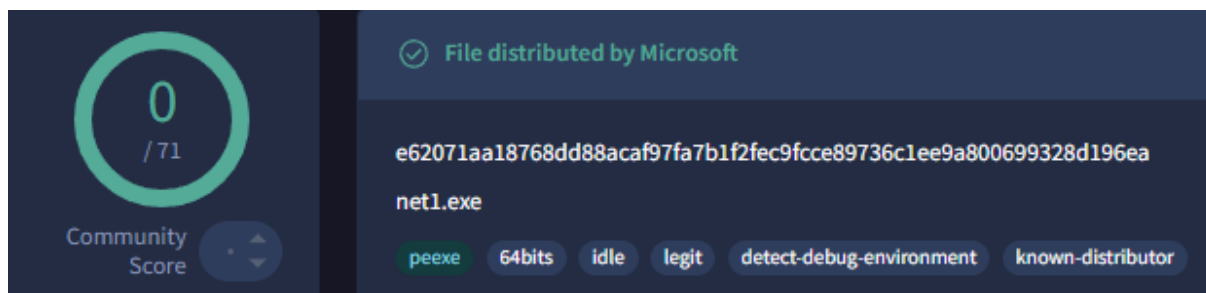
File path

```
\Device\HarddiskVolume2\Windows\System32\net1.exe
```

Executable SHA256

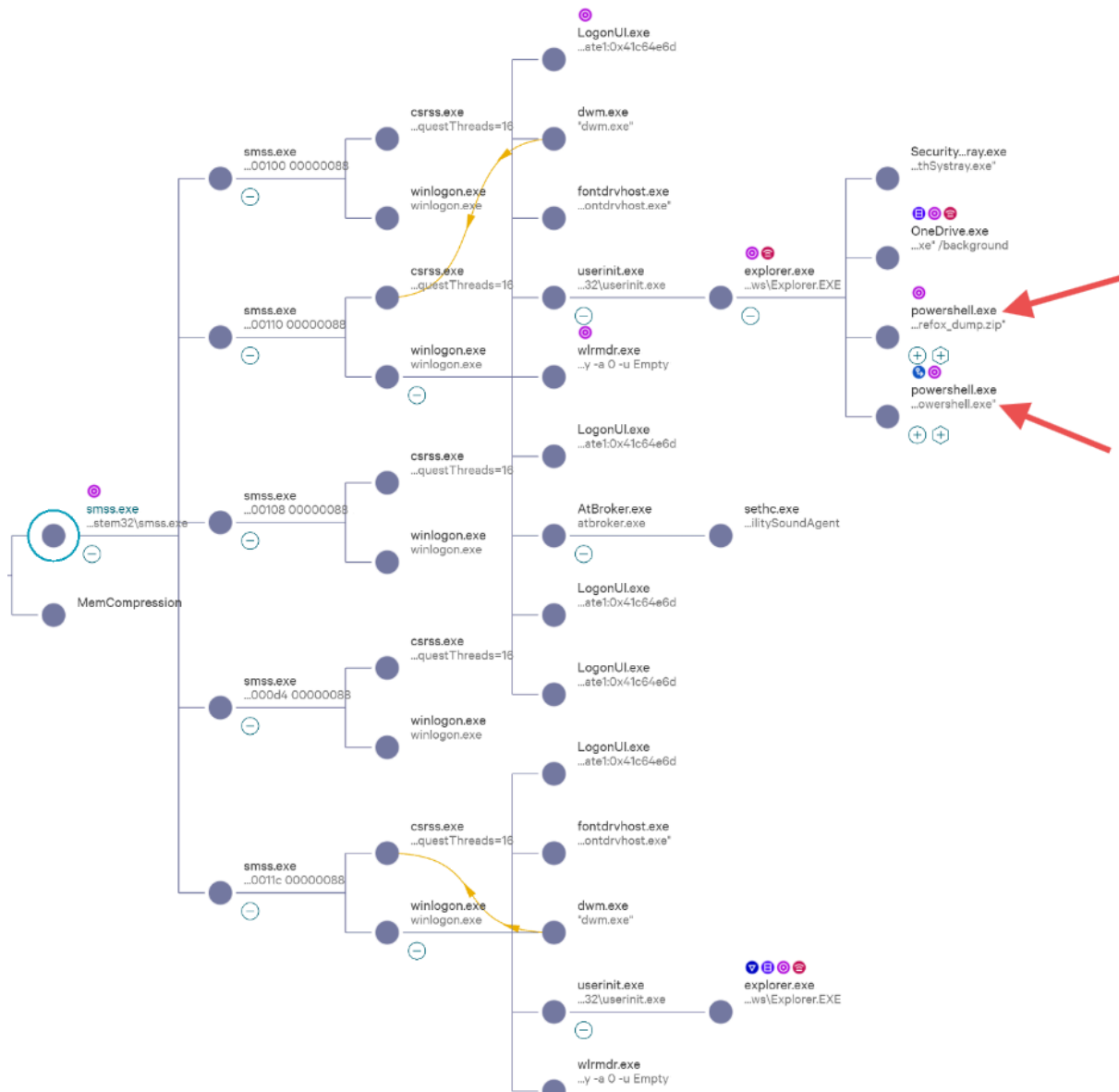
```
e62071aa18768dd88acaf97fa7b1f2fec9fcce89736c1ee9a800699328d196ea
```

[Result there|<https://www.virustotal.com/gui/file/e62071aa18768dd88acaf97fa7b1f2fec9fcce89736c1ee9a800699328d196ea/detection>]



The functional execution of the **net** command. It triggered the Sigma Rule: Local Accounts Discovery. This confirms that the command to create the "adam" account was successfully processed by the Security Account Manager (SAM). The presence of malicious execution parents for this binary further solidifies its role in a coordinated post-exploitation playbook.

Credential Access (Firefox Dump):



Process: powershell.exe

Start time: Feb. 18, 2025 19:40:42

Command line

```
"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -w  
hidden -ep bypass -File  
"C:\Users\[redacted]\AppData\Local\Temp\firefox_dump.zip"
```

File path

```
\Device\HarddiskVolume2\Windows\System32\WindowsPowerShell\v1.  
0\powershell.exe
```

Executable SHA256

```
9785001b0dcf755eddb8af294a373c0b87b2498660f724e76c4d53f9c217c7  
a3
```

The hacker used PowerShell to execute a malicious script disguised as a **.zip** file. The objective is Credential Access—an attempt to extract passwords and session data from the Firefox browser of the user '[redacted]'.

Privilege Escalation (RDP Access):

Process: powershell.exe

Start time: Feb. 18, 2025 19:40:58

Command line

"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"

File path

\Device\HarddiskVolume2\Windows\System32\WindowsPowerShell\v1.0\powershell.exe

Executable SHA256

9785001b0dcf755eddb8af294a373c0b87b2498660f724e76c4d53f9c217c7a3



Process operations

Command history time

Feb. 18, 2025 19:46:07



Command line

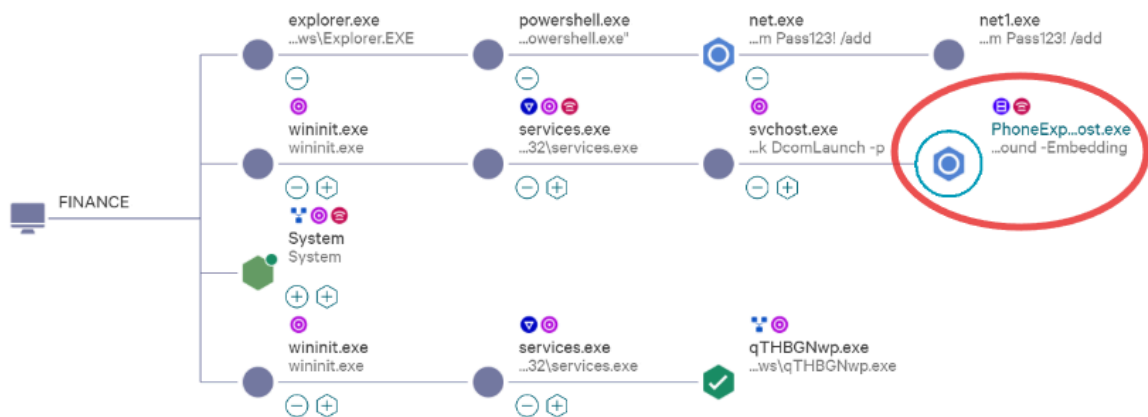
```
net localgroup "Remote Desktop Users" adam /add
```

Simply creating a user account is not enough. To establish persistence, the hacker manually added the "**adam**" account to the Remote Desktop Users group. This ensures that he can log in via RDP at any time.

Strategic Conclusion of Phase 1

The adversary utilized an existing, high-privileged RDP session (**[redacted]**) to manually establish a permanent backdoor. By creating the "adam" user with a weak password ("**Pass123!**"), the attacker ensured they could regain access even if the primary compromised account was secured or the session was terminated. The 40-minute gap between this phase and the subsequent malware deployment suggests a calculated "wait-and-see" approach.

Observed Command 2:



② Phase 2 : Defense Evasion (Security Hook Bypassing)

Process: PhoneExperienceHost.exe

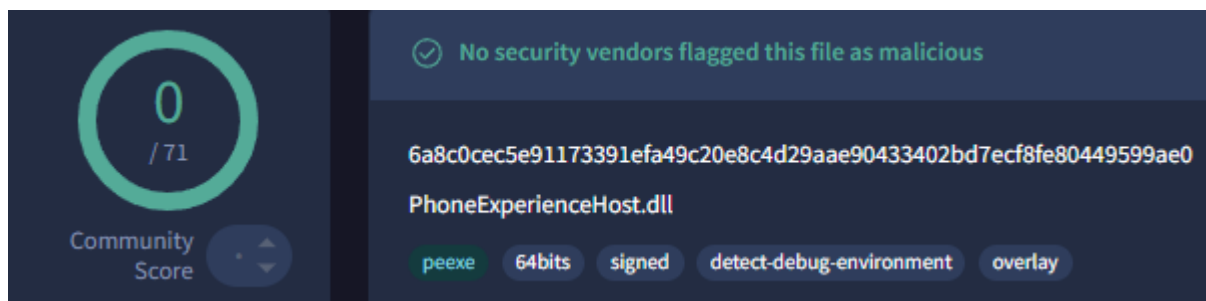
Start time: Feb. 18, 2025 19:27:27

End time: Feb. 18, 2025 19:29:21

Executable SHA256

6a8c0cec5e91173391efa49c20e8c4d29aae90433402bd7ecf8fe80449599ae0

[Result there][<https://www.virustotal.com/gui/file/6a8c0cec5e91173391efa49c20e8c4d29aae90433402bd7ecf8fe80449599ae0>]



Identified by CrowdStrike as an automated lead:

Detection: Defense Evasion via Impair Defenses

Detection Timestamp: Feb. 18, 2025 20:05:52

Command line

"C:\Program

Files\WindowsApps\Microsoft.YourPhone_1.25021.94.0_x64__8wekyb3d8bbwe\PhoneExperienceHost.exe" -ComServer:Background -Embedding

File path

\Device\HarddiskVolume2\Program

Files\WindowsApps\Microsoft.YourPhone_1.25021.94.0_x64__8wekyb3d8bbwe\PhoneExperienceHost.exe

This activity was flagged by CrowdStrike as a **high**-severity Defense Evasion event. While the binary is a signed Microsoft component, its behavior during this session was malicious.

The process was detected performing system calls by bypassing UMPPC

Command line

"C:\Windows\system32\net.exe" user adam Pass123! /add

Start time

Feb. 18, 2025 19:27:20

↓

Start time

Feb. 18, 2025 19:27:27

Command line

"C:\Program Files\WindowsApps\Microsoft.YourPhone_1.25021.94.0_x64__8wekyb3d8bbwe\PhoneExperienceHost.exe" -ComServer:Background -Embedding

This occurred at 19:27:27, exactly 7 seconds after the unauthorized account "adam" was created. This proves it was a coordinated step to hide the tracks of the newly created persistent backdoor.

Network Activity: **13.107.5.93** (Port 443) / **default.exp-tas.com**

Remote	Port	Time
13.107.5.93	443	Feb. 18, 2025 19:27:46

Domain	Time
default.exp-tas.com	Feb. 18, 2025 19:27:46

This is a legitimate Microsoft domain used for "Experience Transformation Services." The adversary cleverly allowed the process to perform its standard network check-in to make the execution appear routine and blend in with legitimate system traffic, while simultaneously performing the low-level hook bypass in memory.

[Result here]<https://www.virustotal.com/gui/ip-address/13.107.5.93/detection>]

0
/91

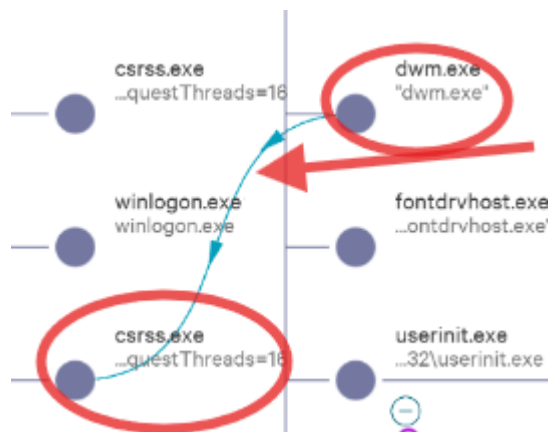
Community Score

8 detected files communicating with this IP address

13.107.5.93 (13.107.4.0/22)

AS 8068 (Microsoft Corporation)

Memory Injection:



Processes: dwm.exe,csrss.exe

Start time: Feb. 18, 2025 19:39:44 and 19:39:46

dwm.exe

Command line

`dwm.exe`

File path

`\Device\HarddiskVolume2\Windows\System32\dwm.exe`

Executable SHA256

`de3d734f5cc52c9b58fedf1591c7f9ac28899e96d6834f73eccef9a156838756`

csrss.exe

Command line

`%SystemRoot%\system32\csrss.exe ObjectDirectory=\Windows
SharedSection=1024,20480,768 Windows=On SubSystemType=Windows
ServerDll=basesrv,1
ServerDll=winsrv:UserServerDllInitialization,3
ServerDll=sxssrv,4 ProfileControl=Off MaxRequestThreads=16`

File path

`\Device\HarddiskVolume2\Windows\System32\csrss.exe`

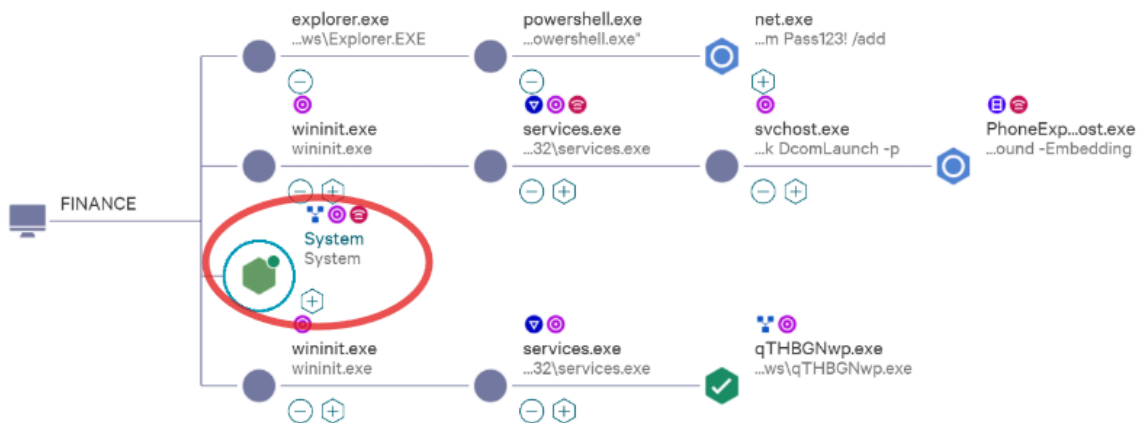
Executable SHA256

`9e63d657b41e13b75aebb261e7f93c0655d52ee82811b37e7470f4119e5b6054`

Telemetry identified an Injected Thread originating from **dwm.exe** and targeting **csrss.exe**. This indicates a Defense Evasion (T1055) technique used to run malicious code inside a trusted system process to avoid detection and capture sensitive memory data.

The process performed system calls by bypassing User Mode Process Prevention (UMPPC) hooks. These hooks are the "eyes" of the EDR in the system's memory. By bypassing them, the adversary ensured that subsequent malicious commands would remain invisible to the sensor's API monitoring.

Observed Command 3:



③ Phase 3: Lateral Movement & RemCom Deployment

Process: System

Start time: Feb. 19, 2025 01:31:25

Executable SHA256 (Windows Kernel)

03312a19baa7ab137c09127c6feb58c05216a7880d3c9e6ae54a8bcda460f92a

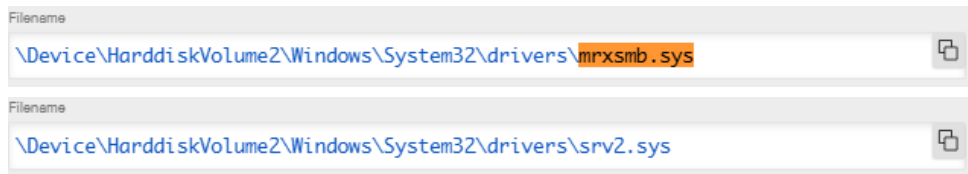
Written to disk malicious file - **qTHBGNwp.exe**

SHA256 on file write (RemCom)

3c2fe308c0a563e06263bbacf793bbe9b2259d795fcc36b953793a7e499e7f71

The System process (Windows Kernel) was identified as the actor responsible for writing the malicious payload to the disk. This activity is a definitive indicator of Lateral Movement via SMB/Admin Shares.

The loading of kernel drivers **mrx smb.sys** (SMB Client) and **srv2.sys** (SMB Server) proves that a remote compromised host pushed the file **qTHBGNwp.exe** to the [redacted] workstation's administrative shares.



CrowdStrike flagged:

Detection: Malware via PUP

Detection Timestamp: Feb. 18, 2025 20:05:51

Action taken: File quarantined + File blocked

Associated MD5

6983f7001de10f4d19fc2d794c3eb534

Associated file

\Device\HarddiskVolume2\Windows\qTHBGNwp.exe

The loading of kernel drivers **mrx smb.sys** and **srv2.sys** confirms the file **qTHBGNwp.exe** was pushed to the host over the network via SMB.

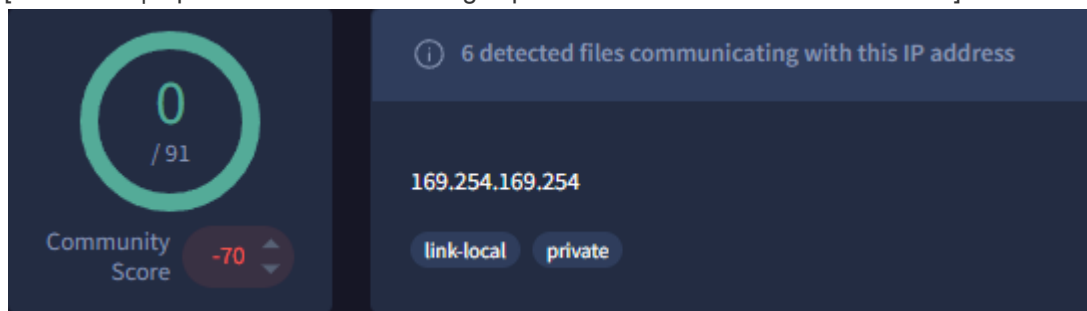
The file is identified as RemCom (a Remote Administration Hacktool). It was set to be executed by the Service Control Manager (**services.exe**).

The file written was **C:\Windows\qTHBGNwp.exe**. Although the **System** process is a trusted core component, the Falcon sensor successfully associated the file-write operation with a known malicious hash identified as RemCom (a Remote Administration Hacktool). It was intended to be executed by the Service Control Manager (**services.exe**).

During this phase, network telemetry shows the host attempting to connect to the Instance Metadata Service (IMDS) at **169.254.169.254**. This suggests the adversary (or the automated RemCom tool) was performing environment reconnaissance to identify cloud roles or metadata upon successful delivery.

Remote	Port	Time
169.254.169.254	80	Feb. 18, 2025 20:33:55

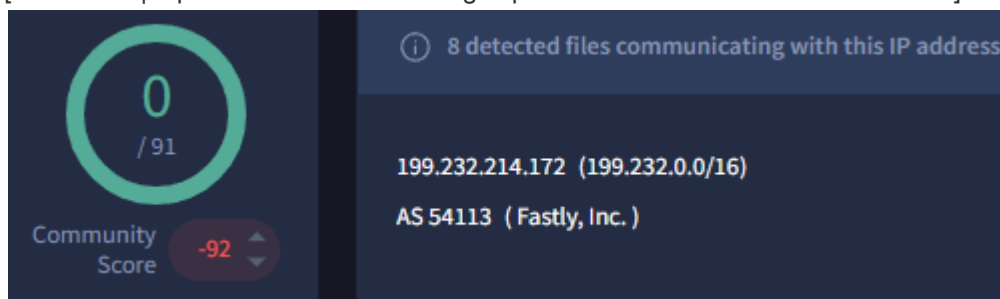
[Resultthere|<https://www.virustotal.com/gui/ip-address/169.254.169.254/detection>]



Telemetry also recorded a connection to **199.232.214.172** (Fastly CDN). The use of Port 0 typically indicates ICMP (Ping) traffic or a Raw Socket operation. In this context, it suggests the adversary's tool was performing a "connectivity check" or a heartbeat signal to an external staging server immediately after the file was written. This adds to the evidence of a coordinated Command and Control (C2) attempt.

Remote	Port	Time
199.232.214.172	0	Feb. 18, 2025 20:04:49

[Resultthere|<https://www.virustotal.com/gui/ip-address/199.232.214.172/detection>]



The EDR intervened at the "Write" stage. By the time the Service Control Manager attempted to execute the file **qTHBGNwp.exe**, the binary had already been neutralized by the sensor. This prevented the establishment of a remote command shell.

④ Phase 4: Execution Attempt & Neutralization (RemCom RAT)

Process: qTHBGNwp.exe

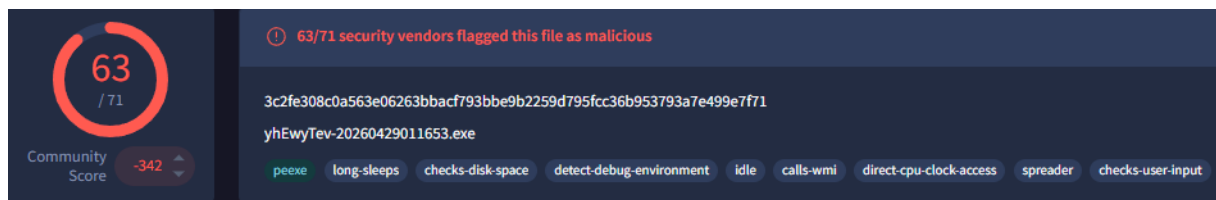
Start time: Feb. 18, 2025 20:04:48

End time: Feb. 18, 2025 20:04:49

Executable SHA256

3c2fe308c0a563e06263bbacf793bbe9b2259d795fcc36b953793a7e499e7f71

[Result here] <https://www.virustotal.com/gui/file/3c2fe308c0a563e06263bbacf793bbe9b2259d795fcc36b953793a7e499e7f71>



Successfully triggered **RemCom_RemoteCommandExecution** (by Florian Roth) and **malware_remcom_strings**. These rules detect specific binary strings unique to the RemCom hacktool.

The execution context matches Sigma rules for "Insecure PowerShell Policies", linking the Phase 1 bypass attempts to this final payload delivery.

Confirmed as a Remote Access Trojan (RAT) and Hacktool, used by advanced threat actors (e.g., UNC1945) for targeted lateral movement.



Identified by CrowdStrike as an automated lead:

Detection: Lateral Movement via SMB/Windows Admin Shares

Detection Timestamp: Feb. 18, 2025 20:05:54

Command line

C:\Windows\qTHBGNwp.exe

File path

\Device\HarddiskVolume2\Windows\qTHBGNwp.exe

Marked as Unique, confirming this binary is not part of the standard [redacted] workstation baseline.

Timeline of Prevention: The process was initiated at 20:04:48. Within one second, the Falcon sensor blocked the execution and moved the file to quarantine.

Final Status: Blocked & Purged. The attempt to establish a remote Command & Control (C2) session failed completely.

"PatternDisposition": "2048" **2048 (Confirmed Policy Block)**

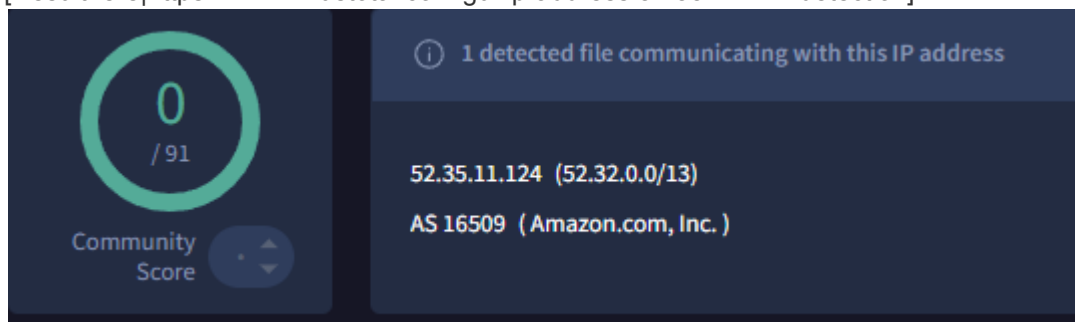
Raw telemetry recorded outbound UDP/137 (NetBIOS) traffic targeting multiple internal hosts ([redacted], [redacted], [redacted]). This confirms the RemCom payload was actively performing

Network Service Scanning (T1046) to identify further targets for lateral movement.

```
NetworkAccesses[6].RemoteAddress: [redacted]
NetworkAccesses[6].RemotePort: 137
NetworkAccesses[7].AccessTimestamp: 1771463074
NetworkAccesses[7].AccessType: 0
NetworkAccesses[7].ConnectionDirection: 0
NetworkAccesses[7].IsIPv6: false
NetworkAccesses[7].LocalAddress: [redacted]
NetworkAccesses[7].LocalPort: 137
NetworkAccesses[7].Protocol: UDP
NetworkAccesses[7].RemoteAddress: [redacted]
NetworkAccesses[7].RemotePort: 137
NetworkAccesses[8].AccessTimestamp: 1771463074
NetworkAccesses[8].AccessType: 0
NetworkAccesses[8].ConnectionDirection: 0
NetworkAccesses[8].IsIPv6: false
NetworkAccesses[8].LocalAddress: [redacted]
NetworkAccesses[8].LocalPort: 137
NetworkAccesses[8].Protocol: UDP
NetworkAccesses[8].RemoteAddress: [redacted] [redacted-internal-hosts]
```

In addition to previously identified IPs, a connection to **52.35.11.124** (Port 443) was documented, indicating multi-homed Command & Control (C2) communication attempts.

[Result here] <https://www.virustotal.com/gui/ip-address/52.35.11.124/detection>



The event summary confirms **PatternDispositionValue: 2176**. This status guarantees that the Prevention Engine successfully blocked the process execution and initiated quarantine, ensuring zero impact on the host.

```
PatternDispositionValue: 2176
```

Analysis

A thorough analysis of associated processes (**lsass**, **services**, **svchost**) has been conducted. No anomalous activity indicating additional attack vectors or hidden backdoors within system processes was detected. All network and registry activity within these branches has been deemed legitimate system background activity (baseline).

Command Line Breakdown: Phase 1 (Persistence & Credential Harvesting)

- **"C:\Windows\system32\net.exe" user adam Pass123! /add**

Unauthorized Account Creation → The adversary established a local backdoor account named "**adam**". The use of a weak, static password (**Pass123!**) is a common indicator of a manual "hands-on-keyboard" intrusion.

Software Packing/Entropy → Analysis of **net.exe** during this event showed unusual entropy, suggesting potential Process Hollowing or binary tampering to mask the account creation from basic heuristic monitors.

- **net localgroup "Remote Desktop Users" adam /add**

Privilege Escalation → By adding the unauthorized user to the RDP group, the attacker ensured persistent, administrative remote access, bypassing the need for future exploit-based entry.

- **powershell.exe -w hidden -ep bypass -File "C:\Users\[redacted]\AppData\Local\Temp\firefox_dump.zip"**

-w hidden & -ep bypass → Standard adversary tradecraft to hide the console window and ignore local script-signing policies.

Credential Access → The script, disguised as a **.zip** file, targeted the extraction of stored passwords and session cookies from the Firefox browser of the **[redacted]** user.

Command Line Breakdown: Phase 2 (Defense Evasion & EDR Blinding)

PhoneExperienceHost.exe (UMPPC Hook Bypassing)

Impair Defenses → This signed Microsoft binary was manipulated to perform system calls while bypassing User Mode Process Prevention (UMPPC) hooks.

Blinding the Sensor → By "silencing" the hooks, the adversary attempted to make the subsequent deployment of the RemCom RAT invisible to the Falcon sensor's API monitoring. The 7-second correlation with the account creation proves this was a calculated tactical step.

- **dwm.exe** → **csrss.exe** (Memory Injection)

Process Injection → Telemetry identified an Injected Thread into the critical system process **csrss.exe**. This allowed the attacker to run code in a trusted context, facilitating stealth and the capture of sensitive memory-resident data.

Command Line Breakdown: Phase 3 & 4 (Lateral Movement & RAT Deployment - Neutralized)

- **System (SMB Payload Delivery)**

mrxsmb.sys / srv2.sys → The loading of these drivers confirms the file qTHBGNwp.exe was pushed to the host via SMB/Admin Shares (C\$). This marks the transition from local persistence to active Lateral Movement.

- **C:\Windows\qTHBGNwp.exe (RemCom RAT)**

Service Execution → The file was set to be executed by the Service Control Manager (**services.exe**) to gain SYSTEM privileges.

Network Scanning (UDP/137) → Raw telemetry confirms the payload immediately performed NetBIOS scanning against internal hosts ([redacted], [redacted], [redacted]), proving intent to spread further into the [redacted-domain] domain.

The Verdict (SUCCESSFUL BLOCK) → Telemetry confirms PatternDisposition: **2176 (2048)**. The Falcon sensor intercepted the execution within one second. The binary was Purged, and no C2 session was established.

Potential Impact

1. **Persistent Backdoor Access (Partial Success):** Although the RAT was blocked, the manual creation of the "adam" account and its addition to the RDP group constitutes a successful persistence event. If not remediated, the attacker can regain access at any time via legitimate RDP.
2. **Internal Network Reconnaissance (Prevented):** The outbound NetBIOS scanning indicates the adversary had already mapped internal targets. If the RemCom service had initialized, it would have led to a rapid "worm-like" spread of malware across the [redacted] subnet.
3. **Data Exfiltration (Firefox Harvesting):** The attempt to dump Firefox credentials suggests a high interest in financial data and web-based portal access. Success here would lead to unauthorized access to external banking or corporate applications.
4. **Cloud Infrastructure Exposure:** The query to **169.254.169.254** (IMDS) shows the attacker was looking for cloud-service identity tokens. This could have resulted in a "Cloud-to-On-Prem" pivot or the theft of AWS/Azure metadata credentials.
5. **Zero-Dwell Time Neutralization:** Due to the EDR's intervention at the "Write" and "Execution" stages, the attacker failed to achieve an interactive shell. The "Dwell Time" (time from RAT delivery to block) was effectively zero seconds, preventing any actual damage to data integrity.

Response:

CrowdStrike Falcon detection page for the qTHBGNwp.exe event — Action taken: Process killed + File quarantined (Purged). The primary RemCom RAT payload was neutralized (SHA256: 3c2fe308c0a563e06263bbacf793bbe9b2259d795fcc36b953793a7e499e7f71). The binary was delivered via SMB administrative shares and attempted to execute as a system service to gain high privileges. Execution was terminated by the EDR's behavioral engine in less than 1 second after initiation.

Unlike the compiled binaries, the unauthorized local account "adam" and the staging script C:\Users\[redacted]\AppData\Local\Temp\firefox_dump.zip were not automatically removed and remain on the host. Manual remediation is required to delete the "adam" user account, scrub the "Remote Desktop Users" group, and remove the residual ZIP artifact to eliminate unauthorized persistence. Additionally, a forensic sweep of internal hosts [redacted], [redacted], and [redacted] is recommended due to recorded NetBIOS scanning activity prior to the block.

Process

qTHBGNwp.exe

Severity

● Low

Description

This file is classified as Adware/PUP based on its SHA256 hash.

Command line

C:\Windows\qTHBGNwp.exe

File path

\Device\HarddiskVolume2\Windows\qTHBGNwp.exe

Actions taken

Process blocked

File quarantined

Objective

Falcon Detection Method

Tactic

 Quarantined files

Hash

3c2fe308c0a563e06263bbacf793bbe9b2259d795fcc36b953793a7e499e7f71

Filename

qTHBGNwp.exe

Time quarantined

Feb. 18, 2025 20:04:52

Status

Purged

PatternDispositionDescription: Prevention/Quarantine, process was blocked from execution and quarantine was attempted.
PatternDispositionFlags.ProcessBlocked: true
PatternDispositionFlags.QuarantineFile: true

Overall Analyst Assessment

This incident is assessed as a True Positive (TP) involving a sophisticated, human-operated manual intrusion targeting the [redacted] workstation. The adversary gained initial access via a hijacked interactive RDP session belonging to the [redacted] user. To ensure long-term persistence, the attacker created an unauthorized local account (**adam**) with administrative RDP privileges and simultaneously executed a PowerShell-based script to harvest browser credentials (**firefox_dump.zip**).

To facilitate the final payload delivery and evade detection, the adversary performed advanced Defense Evasion by bypassing UMPPC hooks via **PhoneExperienceHost.exe** and performing memory injection into the **csrss.exe** system process. These maneuvers were intended to "blind" the EDR sensor prior to the deployment of the primary malware. The intrusion culminated in a Lateral Movement attempt via SMB administrative shares to deliver the RemCom Remote Access Trojan (RAT). CrowdStrike Falcon successfully intercepted the execution via behavioral analysis (PatternId 5728), blocking the process in less than one second and purging the malicious binary (**qTHBGNwp.exe**).

Advanced telemetry and raw event analysis confirmed that before being neutralized, the payload initiated NetBIOS scanning targeting internal hosts ([redacted], [redacted], [redacted]) and attempted to query the Instance Metadata Service (IMDS) for cloud environment tokens. While the active RAT threat was neutralized, the incident is only partially contained. The persistence account (**adam**) and the staging ZIP file remain on the host. Immediate manual remediation is required to remove these artifacts and perform a targeted forensic sweep of the identified internal subnet to ensure no further lateral movement was successful.

Mini Attack Visualization

[Hijacked RDP Session Established: user '[redacted]']

↓

[net.exe creates unauthorized account: 'adam' (Persistence)]

↓

[Privilege Escalation: 'adam' added to Remote Desktop Users group]

↓

[Credential Access: powershell.exe dumps Firefox passwords → firefox_dump.zip]

↓

[Defense Evasion (EDR Blinding): PhoneExperienceHost.exe bypasses UMPPC Hooks]

↓

[Stealth Maneuver: Memory Injection initiated (dwm.exe → csrss.exe)]

↓

[Lateral Movement via SMB: System writes payload qTHBGNwp.exe (RemCom)]

↓

[Execution Attempt: services.exe tries to launch RemCom as a System Service]

↓

[Post-Delivery Reconnaissance (Pre-Execution):

- NetBIOS Scanning (UDP/137) targeting [redacted],[redacted],[redacted]
- Cloud Metadata Query (IMDS) at 169.254.169.254]

↓

[C2 Connectivity Check: Heartbeat signal sent to 199.232.214.172 (Port 0)]

↓

[CrowdStrike Detects: Behavioral Analysis (PatternId 5728) + Policy Block (2048)]

↓

[Execution terminated in <1s (**Process Killed & File Purged**)]

↓

[Current State: Partial Remediation (Unauthorized account 'adam' and ZIP artifact remain)]

Recommended actions :

1. Immediate Host Remediation

- **Account Removal:** Immediately delete the unauthorized local account **adam**. Conduct a thorough audit of the "**Remote Desktop Users**" and "**Administrators**" groups to ensure no other persistent accounts were created.
- **Manual Cleanup:** Delete the residual staging artifact **firefox_dump.zip** from **C:\Users\[redacted]\AppData\Local\Temp**.
- **Persistence Audit:** Review the Windows Registry for any unauthorized entries in **Run/RunOnce** keys and inspect **Scheduled Tasks** created between 19:20 and 20:10 on Feb 18.

2. Access & Credential Security

- **Password Reset:** Enforce a mandatory, complex password change for the [redacted] account. Since credential dumping was attempted (Phase 1), assume all browser-stored passwords for this user are potentially compromised.
- **Session Termination:** Terminate all active RDP and network sessions for the [redacted] user across the domain to invalidate any stolen session tokens.
- **RDP Hardening:** Restrict RDP access to the [redacted] workstation using **Network Level Authentication (NLA)**, limit access to specific authorized IP ranges (Admin Jump-host), and implement **MFA**.

3. Network & IOC Controls

- **Infrastructure Blocking:** Blacklist the following malicious C2 and staging endpoints at the perimeter firewall:

199.232.214.172 (External C2/Heartbeat)

52.35.11.124 (Malicious C2 over Port 443)

13.107.5.93 (Associated with suspicious **default.exp-tas.com** traffic during hook bypassing).

- **Fleet Hunting:** Perform an enterprise-wide search for the following Indicators of Compromise (IoCs):
 - **SHA256:**
3c2fe308c0a563e06263bbacf793bbe9b2259d795fcc36b953793a7e499e7f71 (RemCom RAT)
 - **SHA256:**
9785001b0dcf755eddb8af294a373c0b87b2498660f724e76c4d53f9c217c7a3 (Malicious PowerShell Context)
- **Internal Sweep:** Conduct an immediate forensic review of internal hosts [redacted], [redacted], and [redacted] due to identified NetBIOS scanning (UDP/137) performed by the payload.

4. System Hardening (GPO)

- **SMB Security:** Disable **SMBv1** and restrict administrative shares (**C\$**, **ADMIN\$**) to be accessible only by authorized Service Accounts or Domain Admins from specific jump-boxes.
- **PowerShell Policy:** Transition from **Bypass** to **AllSigned** execution policy via GPO. Enable **PowerShell Script Block Logging** to improve visibility into obfuscated scripts.
- **IMDS Protection:** Implement host-based firewall rules to restrict access to the **Instance Metadata Service (169.254.169.254)** to only required system processes, preventing token theft by unauthorized binaries.

5. Escalation & Deep Dive Analysis

- **Root Cause Analysis (RCA):** Investigate the initial RDP entry point. Determine if the [redacted] credentials were compromised via a phishing campaign, a previous data breach, or a brute-force attack (check Event ID 4625 for failed logins).
- **EDR Policy Review:** Coordinate with the Security Engineering team to investigate why the creation of the unauthorized administrative account (**adam**) did not trigger an automated **Block** action earlier in the kill chain (Phase 1).
- **Threat Hunting Handoff:** Provide the identified **Injected Thread** patterns (Phase 2) to the Threat Hunting team to scan for similar "stealth" memory injections in other critical business segments.